* 침입탐지 시스템 : Snort -> 네트워크 트래픽을 더 많이 감시하고 분석함
- 패킷 스니퍼 : 네트워크상의 패킷을 스니핑하여 보여주는 기능
- 패킷 로거 : 모니터링한 패킷을 저장하고 로그에 남기는 기능
- 네트워크 IDS/IPS : 네트워크 트래픽을 분석하여 공격을 탐지/차단하는 기능

* snort rule : snort rule/signature은 크게 헤더 부분과 바디 부분으로 구성되어 있음
- 헤더 : 처리 방식, 프로토콜, IP주소, 포트번호 등 처리할 패킷을 판단하는 기준을 명시
-> Rule Action : 패킷이 탐지되었을 때 처리 방식으로 8가지 유형이 있음
-> Protocols : 탐지할 프로토콜, 현재 4가지 프로토콜을 지원함 (TCP, UDP, ICMP, IP)
-> IP Address : 출발지/목적지 IP, 출발지 정보는 공격자의 IP를 알지 못하는 경우가 대부분이기 때문에 any 로 지정함
-> Port Numbers : 출발지/목적지 Port -> 포트 범위를 지정할 경우 콜론을 이용하여 표시 함
-> Direction Operator : -> 단방향, <> 양방향, <- 방향 지시자는 없음 !!!!

- 바디 : 패킷을 탐지하기 위한 규칙을 명시

* snort rule 헤더에서 Action 의 유형
- alert : 선택한 alert 방식을 이용해서 alert를 발생시키고 패킷을 로그에 남긴다
- log : 패킷을 로그에 남긴다
- pass : 패킷을 무시한다
- activate : alert를 발생시키고 대응하는 dynamic rule을 활성화 시킨다
- drop : 패킷을 차단하고 로그에 남긴다
- reject : drop rule과 동일하게 패킷을 차단하고 로그에 남긴 후 TCP일 경우 TCP Reset을 전송하고 UDP의 경우 ICMP port unreachable 메시지를 전송함
- sdrop : 패킷을 차단하지만 로그에 남기지 않는다 (slient)

* snort rule body 설정 - 일반 옵션 설정
- msg : msg 옵션에 기록된 내용이 alert 발생 시 이벤트 이름으로 사용됨
- reference : rule 과 관련된 외부 취약점 정보 참조시 사용
- sid : snort rule id
- classtype : snort는 사용자가 어떤 유형의 공격인지 쉽게 이해하고 우선순위를 결정할 수 있도록 공격 유형과 기본 우선순위를 정의해 놓음 (1 높음, 2 중간, 3 낮음)
- priority : rule의 우선순위에 대해 숫자로 표기함. priority 를 지정하면 classtype의 기본 우선순위를 덮어 씀
- rev : rule의 버전정보로 수정 횟수를 표기함. 수정을 할 때마다 1씩 증가함

=> p 481 의 예제 확인하기

* snort rule body 설정 - 페이로드/범위 관련 옵션 설정

- content : 페이로드에서 검사할 문자열을 지정
- uricontent : content 문자열을 전체 패킷과 비교하는 대신 HTTP 클라이언트 요청 URL 정보를 검사할 문자열 생성
- offset : 페이로드에서 content 패턴 검사할 시작 위치
- depth : offset 부터 몇 바이트까지 검사할 것인지 지정
- distance : 이전 content 패턴에 매칭된 경우, 매칭된 이후 바이트로부터 몇 바이트 떨어진 위치에서 다음 content를 검사할 것인지 지정함
- within : 이전 content 패턴에 매칭된 경우, 매칭된 이후 바이트부터 몇 바이트 떨어진 위치에서 다음 content를 검사할 것인지를 지정
- nocase : 페이로드 검사 시 대/소문자를 구분하지 않음

=> 페이로드 일부분에 대해서 패턴 매칭을 수행하는 것이 성능향상과 오탐을 줄여주는 역할을 함 -> offset, depth, distance, within 등 범위를 지정해주는 옵션의 필요성

=> p 482 예제 확인하기 (offset, depth 계산 방법 포함)

* 룰 바디 설정 : 페이로드/정규표현식 관련 옵션
- ₩ : 특수 문자의 기능을 제거하는 이스케이프 문자
- ^ : ^다음에 오는 문자가 문자열의 시작을 의미함
- $: $ 바로 앞에 있는 문자가 문자열의 끝을 의미함
- . : 임의의 문자 1개를 의미함
- [] : 집합 안에 지정한 문자들 중 하나와 일치
- [^] : 집합 안에 지정한 문자들을 제외한 임의의 문자 하나와 일치 . 예를들어 [^0-9]일 경우 숫자를 제외한 임의의 문자열 하나를 의미함
- | : | 앞에 오는 문자열과 뒤에 오는 문자열 중 하나와 일치. 일반적으로 항목들을 묶어주는 ()와 함께 사용

- * : * 앞에 오는 문자가 0 회이상 나타남
- + : + 앞에 오는 문자가 1회 이상 나타남
- ? : ? 앞에 오는 문자가 0회 또는 1회 나타남
- {x} : {x}자 앞에 오는 문자가 정확히 x회 나타남
- {x,} : {x,} 앞에 오는 문자가 x회 이상 나타남
- {x,y} : {x,y} 앞에 오는 문자가 정확히 x회 이상, y회 이하 나타남

=> snort 에서 pcre 옵션은 슬래시 기호 사이에 정규 표현식을 입력한다
=> content 패턴에 매칭되는 HTTP 요청 메시지 중 pcre 에 해당하는 요청이 탐지 됨

* 룰 바디 설정 : 페이로드/HTTP 관련 옵션
- http_method : HTTP method 부분을 검사
- http_uri : HTTP URI 부분을 검사 = http_raw_uri
- http_header : HTTP header 부분을 검사, 요청/응답 헤더에 모두 사용 => http_raw_header
- http_cookie : HTTP Cookie 부분을 검사 => http_raw_cookie
- http_client_body : HTTP 클라이언트 요청의 Body 부분을 검사
- http_stat_code : HTTP 응답의 status_code 부분을 검사
- http_stat_msg : HTTP 응답의 status_message 부분을 검사

=> 페이로드/HTTP 옵션이 들어가면 해당하는 HTTP 요청 라인의 메소드 정보 중 content 값과 일치하는 패킷을 탐지함

* 룰 바디 설정 : Event Threshold (이벤트제한) 관련 옵션 -> 특정 시간 동안 발생하는 이벤트 수를 제한하기 위한 옵션
-> threshold:type <limit|threshold|both>, track <by_src|by_dst>, count <c>, seconds <s>

- limit : 매 s초 동안 c번째 이벤트까지 action을 수행함
- thredhold : 매 s초 동안 c번째 이벤트마다 action을 수행함
- both : 매 s 초 동안 c번째 이벤트시 단 한번 action을 수행함
- track 에서의 by_src 는 출발지 IP를 기준으로 추적하라는 뜻이고 by_dst는 목적지IP 기준으로 추적하라는 뜻임

* snort를 사용한 FTP root 로그인 시도 탐지
-> ftp서비스는 평문으로 송수신 하기 때문에 아이디와 패스워드가 쉽게 노출될 수 있다. 따라서 FTP 서비스 사용을 제한하거나 불가피하게 사용할 경우에는 중요 계정인 root 계정의 직접 접속을 제한하여 root계정의 패스워드가 노출되지 않도록 한다

* snort를 사용한 root Telnet root 로그인 성공 탐지
-> root 계정의 원격 접속 제한 : root 계정은 시스템을 관리하는 중요 계정이므로 외부에서 Telnet, SSH 등으로 직접 로그인이 가능하면 불법적인 침입자의 목표가 될 수 있다. 따라서 root계정에 대한 원격 접속을 허용하지 않도록 설정한다.

* Telnet(SSH, FTP) 로그인 Brute Force/Dictionary Attack 공격 탐지 -> 공격자에 의한 패스워드 무작위 공격이나 사전 대입공격 발생시 암호입력 실패 횟수를 적절하게 제한하고 공격 시간을 지체시켜 패스워드 유출 위험을 줄인다

* HTTP GET Flooding 공격 탐지, TCP SYN Flooding 공격 탐지, UDP/ICMP Flooding 공격 탐지
* 비 정상 패킷 : RFC (Request for Command) 문서에 정의된 프로토콜 표준에 위배되는 패킷들을 말한다 -> 비정상적인 패킷을 제대로 처리하지 못하는 IDS/IPS 또는 침입차단시스템을 우회하기 위한 목적 -> 시스템이 비정상적인 패킷을 제대로 처리하지 못하여 장애나 오류가 발생하도록 하기 위한 목적

* 인터넷 구간의 사설 IP는 볼 수 없다. 따라서 인터넷 구간에서 유입되는 트래피그이 출발지 IP주소가 사설 IP로 되어 있다면 이를 탐지/차단함
- 사설아이피대역 : 10.0.0.0 ~ 10.255.255.255(10.0.0.0/8), 172.168.0.0 ~ 172.31.255.255(172.16.0.0/12), 192.168.0.0 ~ 192.168.255.255(192.168.0.0/16)

* 출발지와 목적지가 동일한 IP -> Land Attack 이라 하며 시스템의 장애를 유발할 수 있으므로 탐지/차단 함
-> snort 에서 sameip 옵션 사용 가능

* 비정상 TCP 패킷 -> SYN 과 FIN 은 동시에 설정할 수 없는 플래그임
-> 일부 구형의 IDS/IPS/방화벽 제품들이 플래그를 제대로 탐지하지 못하고 FIN 플래그를 포함한 패킷을 허용하는 경우가 있고 FIN은 연결을 종료하는 플래그로 일부 시스템에서는 이러한 플래그 패킷에 대해 로그를 남기지 않는 특성이 있어 많은 스캐닝 도구들이 SYN-FIN 패킷을 많이 사용 함 , 추가적으로 일반적으로 클라이언트는 1024 이상의 포트를 사용함
-> snort rule 에서 flags : SF 형식으로 사용함
-> + 연산자가 있으면 SYN, FIN은 반드시 포함하고 다른 플래그도 설정될 수 있음

-> * 연산자가 있으면 지정한 플래그를 하나 이상 포함한 경우를 말함, 즉 SYN 또는 FIN 또는 SYN_FIN을 포함하고 다른 flags들도 설정될 수 있음
-> ! 연산자가 있으면 지정한 플래그를 포함하지 않은 설정을 의미한다

* FIN 플래그만 설정된 비정상 TCP 패킷 -> FIN 스캔 -> flags : F
* 플래그가 설정되지 않은 비정상 TCP 패킷 (NULL 패킷) -> Null스캔 -> flags : !UAPRSF

=> Null 스캔과 FIN 스캔 모두 스텔스 스캐닝 기법이다.

* 침입 차단 시스템 : 패킷 필터링 기능이 있는 리눅스 커널에 내장된 netfilter 기능을 관리하기 위한 도구로 rule 기반의 패킷 필터링 기능 제공, 상태 추적 기능 제공 (-> 상태추적 기능은 방화벽을 통과하는 모든 패킷에 대한 연결 상태를 추적하여 이 정보를 메모리에 기억하고 있다가 기존의 연결을 가장하여 접근할 경우 메모리에 저장된 상태 목록과 비교하여 적합하면 통과하고 그렇지 않으면 거부하는 기능을 말함 -> 연결된 상태의 패킷에 대해서는 더 이상의 패턴 매칭 검사를 수행하지 않으므로 성능상의 장점을 가지고 위조된 패킷을 차단할 수 있으므로 보안상의 장점도 있다, 네트워크 주소변환(NAT) 기능 제공, 패킷 레벨에서의 로깅 기능제공, 확장 모듈을 통한 다양한 기능 제공 가능

* Table : iptables가 제공하는 기능을 의미, Filter, Nat, Mangle이 있음. Filter 기능은 가장 기본적인 가능으로 테이블을 명시하지 않으면 기본적으로 Filter 테이블을 의미한다
* 체인 : 패킷이 이동하는 경로 - 필터 테이블 체인에는 INPUT(방화벽을 최종 목적지로 함), OUTPUT(방화벽을 최초 출발지), FORWARD(방화벽을 통과하는 채널)
* 룰 : 패킷을 필터링하기 위한 규칙

* iptabels 기본 구문 : iptables [테이블] [체인] [룰] [타겟]
-> 대소문자를 구분함

* iptables 테이블 설정 : -t [테이블]
* iptables 체인 설정 : iptables -[A | I | D] [체인] -> -A : append 모드, 해당 체인의 가장 마지막에 룰을 추가함/ -I : insert모드, 해당 체인의 첫 행에 룰을 추가함, -D : delete 모드, 해당 룰을 삭제하거나 "-D 체인 n" 형식으로 행번호 n을 지정하여 특정 위치의 룰을 삭제할 수 있음.

* iptables 룰 설정 : IP/ICMP/TCP/UDP 모두 호스트를 식별하기 위해서 IP를 이용함
- -s [IP 또는 IP 대역] : Source IP를 명시함. 명시하지 않으면 any
- -d [IP 또는 IP 대역] : Destincation IP를 명시함. 명시하지 않으면 any

* TCP/UDP의 경우 포트 번호를 통해 서비스를 식별함
- - -sport [포트번호] : 출발지 포트 명시 (- 가 두개붙음)
- - -dport [포트번호] : 목적지 포트 명시 (- 가 두개붙음)

* ICMP의 경우 타입과 코드를 통해서 메시지를 식별함
- - -icmp-type [메시지타입] : 메시지 타입을 명시함 (- 가 두개붙음)

* TCP 패킷 행동 유형에 따른 필터링 룰 설정으로 다음의 모든 옵션은 TCP 프로토콜이 먼저 선행되어야 함 (-p tcp)
- - - tcp-flags [검사할 플래그 리스트] [설정되어야 할 플래그 리스트] : 예를들어 - - tcp-flags SYN,FIN SYN,FIN 형식으로 작성함 (- 가 두개붙음)
- -m state - - state [탐지할 상태] (state 앞에 - 가 두개 붙음) : 탐지할 상태에는 NEW, ESTABLISHED, RELATED, INVALID 가 있음

* 타겟 설정 : -j [정책] -> 룰에 매칭될 때 적용할 정책을 지정함
- -j ACCEPT : 해당 패킷을 허용함
- -j DROP : 해당 패킷을 차단 한 후 아무런 응답 메시지도 전송하지 않음
- -j REJECT : 해당 패킷을 차단한 후 ICMP 에러 메시지로 응답함
- -j LOG : 탐지 로그를 남김. 일반적으로 "/var/log/messages"에 남긴다

* iptables -L [체인] -n : -L [체인] -> 해당 체인에 등록된 룰 리스트를 확인할 수 있음
* iptables -F [체인] : 해당 체인에 등록된 모든 룰 정보를 삭제 한다.
* iptables -P [체인] [ACCEPT | DROP | REJECT] : -P 를 통해 해당 체인의 기본정책을 지정한다. 기본정책은 해당 체인의 모든 룰에 매칭되지 않으면 적용되는 정책이다. 일반적으로 Negative 정책을 사용한다.
- Negative 정책 : default policy를 DROP/REJECT로 하고 허용할 부분만 ACCEPT 하는 정책
- Positive 정책 : default policy를 ACCEPT로 하고 차단할 부분만 DROP/REJCT 하는 정책

* 상태 추적 : NEW 상태 (최초로 들어온 패킷의 상태. 상태 추적 테이블에 연결 정보를 가지고 있지 않은 경우로 일반적으로 TCP의 SYN 에 해당함), ESTABLISHED (상태 추적 테이블에 연결 정보를 가지고 있는 패킷의 상태 -> 연관된 연결정보는 연결 시의 포트 정보가 서비스 수행 중에 새롭게 추가 될 수 있다는 것 -> FTP 프로토콜이 해당함 -> 데이터

채널로 송수신되는 패킷들은 모두 RELATED 상태가 됨), INVALID (어떤 상태에도 해당하지 않는 패킷 상태를 의미함)

* 프로토콜 유형 : TCP 프로토콜 상태는 NEW(SYN) -> ESTABLISHED (SYN+ACK) , UDP 프로토콜은 비연결 프로토콜이기 때문에 연결 상태를 유지 하지 않음(프로토콜 수준에서 연결 상태 정보가 없음) -> TTL이 유지되는 동안 ESTABLISHED로 간주함

* 위조된 TCP SYN 패킷을 차단하기 위한 룰 설정 - NEW 상태이면서 SYN 플래그를 설정하지 않은 패킷은 DROP (NEW 상태라면 SYN 플래그가 설정된 패킷이어야 하며 이외의 패킷은 모두 조작 된 것임)

* iptables 확장 모듈 : connlimit -> 동일한 IP 또는 IP 대역의 동시 연결 개수에 대한 제한을 할 수 있는 모듈로 디도스 공격에 효과적으로 대응할 수 있다
=> 디도스 공격에 효과적으로 대응할 수 있는 iptables 모듈 -> connlimit

-> - - connlimit-above n : n을 초과하는 동시 연결을 제한한다
-> - - connlimit-mask mask : 0~32 범위의 mask 값을 지정한다. IP대역에 대한 동시연결을 제한 함
-> TCP SYN Flooding 방지 가능

* iptables 확장 모듈 : limit -> 룰에 매칭되는 비율을 제한할 수 있는 기능으로 불필요한 로그를 남기지 않도록 할 때 유용하다.
-> - - limit : 초당/분당/시간당/하루당 매칭되는 제한 건수를 지정한다.
-> limit [n/second(또는 s), n/minute(또는m), n/hour(또는h), n/day(또는 d)
-> 비정상적인 TCP 플래그 조합 패킷 차단 룰 설정

* iptables 확장 모듈 : recent -> 동적으로는 Source IP 목록을 생성하여 이를 기반으로 패킷을 제어하는 기능을 제공하는 모듈
-> - -name : 목록 이름을 지정한다
-> - - set : 해당 목록에 새로운 entry 를 추가한다. 이미 존재하면 해당 entry를 업데이트한다
-> - -rcheck : 해당 목록에 패킷의 source ip가 있는지 체크한다
-> - -update: rcheck와 동일하게 해당 목록에 패킷의 source ip가 있는지 체크하고 있으면 last seen timestamp를 갱신한다
-> - -seconds : - -rcheck 또는 - -update 옵션과 함께 사용된다. 해당 entry의 last seen timestamp가 지정한 초 범위 내에 있는지를 체크한다
-> - -hitcount : - -rcheck 또는 - - update 옵션과 함께 사용된다. 해당 entry의 hit count가 지정한 값 이상인지 체크한다, 일반적으로 - -seconds 옵션과 함께 사용되어 지정한 초 범위내에 hit count 이상으로 패킷이 발생했는지 체크한다

-> SSH brute Force/Dictionary Attack 차단 룰 설정

* 네트워크 보안 솔루션
- 웹방화벽 : 일반적인 방화벽과 달리 웹 애플리케이션 공격에 대응하기 위해 웹 트래픽의 웹 컨텐츠를 분석하고 탐지 및 차단할 수 있는 기능이 있는 보안장비 (난독화된 스크립트를 해제하여 분석할 수 있음, 다양한 웹공격에 사용되는 요청 파라미터 패턴을 분석할 수 있음) , 직접적인 웹 공격 대응 이외에도 정보 유출 방지, 부정 로그인 방지, 웹사이트 위변조 방지등으로 활용이 가능함
- 네트워크 시스템 방화벽 (Firewall) : 네트워크계층의 IP주소와 전송 계층의 Port주소를 기반으로 방화벽 룰셋에 따라 패킷 필터링을 수행하는 보안 장비 , 방화벽은 서로 다른 보안 레벨의 네트워크 경로사이에 위치한다. 인터넷구간과 DMZ, DMZ 와 내부망, 내부망 내 서로 다른 서버존 사이에 위치함. 일반적으로 HA(고가용성) 환경 구축을 위해 Active-standby 또는 Active-Active 방식의 이중화 구정으로 설치함, 최근에는 차세대 방화벽인 NGFW 라 불리는 다양한기능을 가진 방화벽 제품들이 나오고 있음
- 침입탐지시스템 - IDS : 사전에 등록한 알려진 공격 패턴, 임계치 등에 따라 공격을 탐지하는 보안 장비 -> 차단이 목적이 아니라 탐지목적의 장비기 때문에 NIDS 인 경우 미러링 모드로 설치함 , 침입 탐지 방식에 따라 오용 탐지(사전에 알려진 공격 패턴을 기반으로 공격 행위를 탐지하는 방식으로 지식 기반 탐지 또는 시그니처 기반 탐지라고 함 , 오탐률(false postive rate)이 낮지만 미탐률(false negative rate) 이 높음)와 이상 탐지(정상적이고 평균적인 상태를 기준으로 이를 벗어난 행위를 공격 행위로 탐지하는 방식으로 행위 기반 탐지 또는 통계 기반 탐지라고 함, 알려지지 않은 새로운 공격도 탐지할 수 있어 미탐률이 낮지만 오탐률이 높음)로 구분하고 탐지할 데이터 수집원에 따라 호스트 기반(HIDS, 호스트 정보를 수집, ,tripwire -> 파일시스템의 무결성을 검사)과 네트워크 기반(NIDS, 네트워크 트래픽을 수집하여 탐지활동을함, snort, suricata)으로 분류함
- 침입방지시스템 - IPS : 사전에 등록한 알려진 공격 패턴, 임계치 등에 따라 공격을 탐지하고 차단하는 보안 장비 -> 탐지 뿐만 아니라 차단까지 수행하는 장비이기 때문에 일반적으로 공격 행위로 탐지된 패킷의 실시간 차단을 위해 인라인 모드로 서치함
- 디도스 차단 시스템 : Anti-DDos System -> 일반적으로 디도스 공격으로부터 다른 장비들을 보호하기 위해 네트워크 구성상 가장 상단에 위치하는 보안 장비
- APT대응 시스템 : 네트워크 트래픽을 통해 유입되는 실행 파일, 문서파일 등을 추출, 평판조회 및 가상 머신 기반의 샌드박스 환경에서 해당 파일을 직접 실행하여 악성 여부를 판단하는 보안 장비, 일반적으로 엔드포인트 솔루션을 함께 제공하여 가상 머신을 통한 분석이 완료될 때 까지 엔드포인트 파일 실행을 보류하거나 악성 파일로 판단 될 경우 파일 삭제 등의 기능을 수행함

cf. 샌드 박스 : 외부로부터 받은 파일을 바로 실행하지 않고 보호된 영역에서 실행시켜봄으로써 외부로부터 들어오는 파일과 프로그램이 내부 시스템에 악영향을 주는 것을 미연에 방지하는 기술
- 네트워크 포렌식 시스템 : 설치된 네트워크 구간을 통과하는 모든 트래픽을 수집하고 분석할 수 있는 장비 -> 수집한 트래픽은 침해사고 분석 및 내부 감사 등의 목적으로 활용 함
- 무선침입방지시스템 (WIPS) : 인가되지 않은 무선 단말기의 접속을 자동으로 탐지 및 차단하고 보안에 취약한 무선 공유기를 탐지하는 솔루션
- 네트워크접근제어 (NAC) : 과거 IP관리 시스템에서 네트워크에 대한 통제 기능을 더욱 강화한 보안 솔루션, 네트워크 제어 및 통제 기능을 통해서 내부 네트워크가 바이러스나 웜 등이 보안 위협으로부터 안전한 단말기들로 이루어질 수 있도록 강제하는 역할
- 통합보안시스템 (UTM) : 방화벽(firewall) + 침입탐지/방지시스템 (IDS/IPS) + 가상사설망(VPN) + 안티바이러스 + 웹/이메일 필터 등 다양한 보안 기능을 하나의 장비로 통합하여 제공하는 보안 솔루션
- 가상사설망
- Offload (SSL 오프로드 장비) : SSL 트래픽에 대한 가시성 확보를 위해 사용함

cf. SSL 오프로드 : SSL 서버를 대신해서 SSL 트래픽에 대한 모든 암/복화 처리를 수행하는 기능 -> 대상 서버의 SSL 서버 인증서 설치가 필요 함

cf. 어플라이언스 (appliance) : 범용 목적의 불필요한 기능을 제거하고 특정 목적에 최사으이 성능을 내기위해 최적화된 장비
cf. SSL-VA(Visibility Appliance) : SSL 트래픽에 대한 암/복호화 처리에 특화된 전용의 어플라이언스 장비

cf. L7-Switch : 컨텐츠 분석을 통한 패킷 탐지, SSL 오프 로드 기능, 서버 부하 분산(SLB), 장애 조치(FailOver) 등의 다양한 기능을 제공 함

*시스템(단말) 보안 솔루션
- 바이러스 백신
- 엔드포인트 탐지 및 대응 솔루션 (EDR) : PC, 모바일, 서버 등 엔드포인트에서 발생하는 악성 행위를 실시간으로 감지하고 이를 분석 및 대응하여 피해확산을 막는 솔루션, 기존 안티바이러스 제품인 백신은 알려진 패턴(시그니처)을 기반으로 탐지하는 반면 EDR 솔루션은 엔드포인트에서 실행되는 프로세스 기반의 모든 행위를 지속적으로 모니터링하고 이를 기반으로 탐지하기 때문에 알려진 악성 행위뿐만이 아니라 알려지지 않은 악성 행위에 대해서도 사전 대응이 가능하다, 관리자 보고기능 + 가시성 제공 + 엔드포인트에대한 직접적 대응이 가능한 기능이 제공 됨
- 시스템 접근 통제 -> pc 방화벽
- 스팸차단솔루션 -> Anti-Spam Solution : 메일 서버 앞단에 위치하여 프록시 메일 서버로 동작하며 스팸메일 차단 기능뿐만이 아니라 메일에 대한 바이러스 검사, 내부에서 외부로 전송되는 메일에 대한 본문 검색 기능을 통한 내부 정보 유출 방지 등의 확장 기능이 있음

cf. 스팸 : 이메일이나 휴대폰 등 정보통신서비스를 이용하는 이용하는 이용자에게 본인이 원하지 않음에도 불구하고 일방적으로 전송되는 영리 목적의 광고성 정보
- 보안 운영체제 : Secure OS -> 운영체제에 내재한 결함으로 인해 발생할 수 있는 각종 해킹으로부터 보호하기 위해 보안 기능이 통합된 보안 커널을 추가로 인식한 운영체제를 말함, 취약 서비스를 모두 차단하여 계정 관리 및 서비스 관리에 있어 좀 더 나은 보안 체계를 가지고 운영될 수 있도록 함

* 컨텐츠/정보 유출방지 보안 솔루션
- DB 보안 (접근통제)/ DB 암호
- 보안 USB : 보안 기능을 갖춘 USB 메모리
- 디지털저작관리(DRM) : 저작권자가 배포한 디지털 자료나 하드웨어의 사용을 제어하고 이를 의도한 용도로만 사용하도록 제어하는데 사용되는 모든 기술 -> 디지털 컨텐츠 저작권을 보호하려는 목적 -> 파일 자체에 암호를 걸어 권한없는 사용자는 사용하지 못하도록 하거나 문서를 저장할 때 암호화하여 권한이 없는 다른사용자가 문서를 읽지 못하게 함
- 네트워크/ 단말 정보유출방지(DLP) : 조직 내부의 중요 자료가 외부로 빠져나가는 것을 탐지하고 차단하는 솔루션, 정보의 흐름에 대한 모니터링과 실시간 차단 기능을 제공함 -> 네트워크 DLP와 단말 DLP 로 나뉨

* 보안관리(관제) 솔루션
=> 일반적으로 보안 관제 센터에서 실시간으로 '정보수집 -> 모니터링 및 분석 -> 대응 -> 보고' 순으로 수행함
- 전사적 보안 관리 시스템 (ESM) : 다양한 보안 장비를 도입하게 되고 그에 따른 관리의 어려움이 발생함에 따라 다양한 보안장비에서 발생하는 보안정보(로그,이벤트 등)을 통합적으로 수집 및 관리하여 불법적인 행위에 대응할 수 있도록 하는 통합 보안관리 시스템 -> 솔루션 별 보안 정책의 일관성 확보 가능
-> ESM 에이전트(관리대상보안장비에 설치되어 사전에 정의된 규칙에 따른 로그 및 이벤트 데이터를 수집하여 ESM 매니저로 전달하는 기능을 수행함), ESM 매니저(다른말로 엔진이라고도 표현함. ESM Agent를 통해 수집된 데이터를 저장,분석하여 그 결과를 ESM콘솔로 전달하는 기능을 수행함), ESM 콘솔(ESM Manager에 의해 전달된 정보의 시각적 전달, 상황 판단 및 리포팅 등의 기능을 제공하며 ESM Manager와 Agent에 대한 제어/통제를 수행함)로 구분 됨
- 보안정보 및 이벤트 관리 시스템 (SIEM) : ESM 의 진화된 형태로 보안장비뿐만 아니라 각종 서버 장비, 네트워크 장비, 애플리케이션 등 다양한 범위에서 발생하는 로그와 이벤트를 수집하여 빅데이터 기반의 상관관계 분석을 통해 위협을 사전에 차단하는 통합보안관제 솔루션을 말함 -> 데이터 통합/상관관계 분석/알림/대시보드 기능이 있음
- 보안 오케스트레이션, 자동화 및 대응 시스템 (SOAR) : SOAR는 SOA, SIRP, TIP을 폭넓게 포함하는 개념으로 보안 운영에 있어 유입되는 위협에 대해 대응 수준을 자동으로 분류하고 표준화된 업무 프로세스에 따라 사람과 기계가 유기적으로 협력할 수 있도록 지원하는 대응 플랫폼 , 보안 위협에 대한 자동화된 분석과 대응 환경을 만들어 보안 인

력을 효율적으로 운영하면서 분석의 정확도를 높이고 대응 시간을 단축하기 위한 솔루션 -> 자동화된 통합보안관제 솔루션
-> SIRP (Security Incidnet Response Platform) : 보안 사고 대응 플랫폼
-> SOA (Security Orchestration and Automation) : 보안 오케스트레이션 및 자동화
-> TIP (Threat Intelligent Platform) : 위협 인텔리전스 플랫폼

cf. TI (Threat Intelligence) : 사이버 위협 인텔리전스, CTI 라고 표현하기도 하며 외부 위협 동향에 대해 쉽게 파악할 수 있고 알려지지 않은 위협, 지능형 지속 위협과 같은 공격에도 효과적으로 대응할 수 있음 (ATP)

cf. 가트너의 정의 : 현존하거나 발생할 수 있는 위협에 대한 대응을 결정하는 데 사용할 수 있도록 해당 위협에 대한 맥락, 매커니즘, 지표, 예상 결과 및 실행 가능한 조언 등을 포함하는 증거 기반의 지식

cf. 아이사이트 파트너스 정의 : 사이버 위협의 공격자와 그 동기,의도,방법에 대한 지식으로 다양한 경로로 수집, 분석, 전파되어 보안 조직 및 운영 조직의 각 직급 담당자가 기업의 주요 자산을 보호하는데 기여함

cf. 한국인터넷진흥원 : 악성코드 정보, 명령 제어 서버 정보, 취약점 및 침해사고 분석 정보 등 사이버 위협 정보를 체계적으로 수집하고 종합적으로 연관 분석해 관계기관 간 자동화한 정보 공유를 목적으로 하는 예방 대응 시스템

- 위협 관리 시스템 (TMS)
- 패치 관리 시스템 (PMS) : 네트워크에 접속하는 사용자 PC 의 운영체제와 각종 애플리케이션에 대한 패치를 기업 보안 정책에 따라 자동으로 설치, 업그레이드 함으로써 웜이나 바이러스 공격 등으로부터 기업의 IT 환경을 효과적으로 보호 해주는 솔루션
-> PMS 서버 (패치를 배포하고 기업 보안 정책에 따라 이를 위반한 사용자 PC를 인식하고 이들에게 강제적으로 정책에 맞는 수준의 보안을 적용하는 역할을 함)/ PMS 에이전트(서버로부터 패치를 적용하고 사용자 PC의 상태를 점검해서 보안 정책 위반 여부 정보를 서버에 제공하는 역할을 함)로 구성 됨
- 자산관리시스템(RMS)
- 백업/복구 관리 시스템
- 취약점분석시스템
- 디지털포렌식시스템

* 인증 및 암호 보안 솔루션
- 보안 스마트카드
- 하드웨어보안모듈(HSM) : 암호화된 데이터를 보호하는 암호화키/디지털키에 대한 안전한 저장/관리 및 고속의 암호화 처리를 수행할 수 있는 전용의 하드웨어 장비 , 일반적으로 플러그인 카드 또는 컴퓨터나 네트워크 서버에 직접 연결되는 외부 장치 형태로 제공, 클라우드 HSM 이 있음
- 일회용 비밀번호 (OTP)
- 공개키기반구조 (PKI)
- 싱글사인온 (SSO) : 한번의 사용자 인증으로 여러 시스템에 접근할 수있는 통합 인증 솔루션
- 통합접근관리(EAM) : 모든 사용자에 대한 통합 인증과 사용자별/그룹별 접근 권한 통제를 담당하는 권한관리 솔루션
- 통합계정관리(IAM) : 통합계정관리, 통합인증관리, 계정 관리 솔루션 등으로 불림. EAM을 보다 포괄적으로 확장한 보안 솔루션으로 조직이 필요로 하는 보안 정책을 수립하고 자동으로 사용자에게 계정을 만들어주며 사용자는 자신의 위치와 직무에 따라 적절한 계정 및 권한을 부여받을 수 있을 뿐만 아니라 사용자 정보의 변경과 삭제도 실시간으로 반영할 수 있음

* 접근 통제 관점의 구간 구분
- 인터넷 구간 : 인터넷을 통해 외부에서 직접 접근이 가능한 구간
- DMZ : 인터넷 구간과 내부망 사이에 위치한 중간지점으로 접근통제시스템을 통해 접근통제를 수행하면서 인터넷으로부터의 접근과 내부망으로의 접근을 허용하는 구간
- 내부망 : 인터넷으로부터 물리적으로 분리된 망이거나 접근통제시스템에 의해 인터넷으로부터 직접 접근이 불가능하도록 통제/차단되어 있는 구간

* 네트워크 보안장비 설치 모드
- 인라인 모드 : 물리적 네트워크 경로상에 설치되어 연결된 네트워크를 통과하는 모든 트래픽이 거쳐 가도록 하는 모드
-> 패킷 차단 목적의 장비에 적용하는 모드로 네트워크 경로상에 위치하기 때문에 실제 패킷을 탐지하고 차단까지 할 수 있는 장점이 있지만 장비에 장애가 발생할 경우 전체 네트워크 장애로 확산될 수 있는 위험성이 있다

- 미러링 모드 : 미러링 장비를 통해 복제된 패킷을 받아서 탐지하는 모드로 미러모드, out of path 모드라고 함
-> 일반적으로 패킷 차단 기능이 없는 탐지 목적의 장비 에 적용하는 모드로 네트워크 경로를 벗어난 곳에 위치하기ㄷ 때문에 전체 네트워크 가용성에 영향을 주지 않으면서 패킷을 탐지할 수 있는 장점이 있지만 복제된 패킷을 탐지하기 때뭉네 실제 패킷을 차단하기 어렵다는 단점이 있다
-> 탐지 트래픽이 TCP 통신인 경우 TCP Reset 방식을 통해 공격 행위로 탐지된 TCP 연결의 중단을 지원함

* 보안 솔루션 취약점 - 계정 관리
- 보안 장비 default 계정 변경 , default 계정 변경이 불가능한 경우 기본 패스워드 변경으로 보완

- 보안 장비 default 패스워드 변경 -> 디폴트 패스워드를 특수문자, 숫자, 영문 대소문자 포함하여 8자리 이상으로 변경

- 보안장비 계정별 권한 설정 -> 권한 없는 사용자의 설정 변경으로 인한 시스템 침입 경로 유출 위험을 줄이고 관리자 계정이 아닌 일반 계정이 공격자에게 탈취되었을 때 보안장비를 장악하지 못하도록 해야 함
- 보안장비 계정 관리 -> 사용하지 않는 불필요한 계정을 관리함 (불필요한 계정을 관리하지 않으면 공격자의 무작위 대입 공격, 사전 대입 공격에 의해 불필요한 계정을 통한 접근 위험이 존재하며 공용계정 및 휴면계정이 존재할 경우 계정 탈취 시 침해사고 발생 때 사후 추적의 어려움이 있다) -> 계정은 1인 1계정의 사용을 원칙으로 운영하고 계정 공유를 금지함 -> 공용계정 사용 시 사용자별 계정 생성 및 시스템 접근 이력을 관리하여 책임 추적성을 확보한다

cf. 책임추적성 : 시스템 내의 각 개인은 유일하게 식별되어야 한다는 정보 보호 원칙

- 보안관리 원격 관리 접근 통제 : 보안장비에 원격으로 접근할 수 있는 IP를 등록함으로써 비인가자의 보안장비 접근을 차단하고 보안장비에 접근이 허용된 특정인들만 보안장비에 접근이 가능하도록 함 -> 관리자 IP 또는 특정 IP 및 계정에서만 접속할 수 있도록 설정함

- 보안장비 보안 접속 : SSH, HTTPS 등의 암호화 접속을 통하여 공격자의 데이터 스니핑 공격을 차단한다.

* 세션 타임아웃 설정 : 보안 장비 관리 작업을 완료한 후 관리자의 부주의로 계정이 접속된 상태로 방치 되는 경우를 방지하며 사용하지 않는 세션을 종료하여 가용성을 높일 수 있음 -> 세션 타임 아웃 기능 활성화

* 취약점 점검 도구 : 특정 시스템, 네트워크 및 애플리케이션 등에 존재할 수 있는 보안 취약점을 사전에 점검하여 보안을 강화하기 위한 도구를 말함. -> 네트워크 보안 취약점, 시스템 보안 취약점, 웹 보안 취약점이 있음
- 네서스 : 미국 테너블사가 개발/배포하는 취약점 점검 도구로 로컬 또는 원격지에서 다양한 방법을 통해 시스템,네트워크, 웹 애플리케이션 등 알려진 취약점에 대한 점검을ㄹ 수행하며 점검을 통해 취약점의 내용과 해결 방법을 상세하게 제공함

-> 클라이언트/서버 구조로 동작함, 사용아 자유롭고 플러그인 업데이트 등이 쉬움, HTML 등 여러 형태로 결과를 리포트 해줌 , OS 에 상관없이 지원
- 닉토 : 공개용 웹 취약점 점검 도구로 웹 해킹에 대응하기 위해 웹서버나 웹 기반의 응용 프로그램 취약점을 점검할 수 있는 대표적인 프로그램

-> 방대한 취약점 DB를 통해 웹서버의 잘못된 설정, 기본적으로 설치되는 파일이나 스크립트의 존재 유무, 안전하지 못한 파일이나 스크립트의 유무 등 웹서버에 대한 포괄적 점검을 수행한다.

* 무결성 점검 도구 -> tripwire : 파일 시스템의 상태 추적 및 허가받지 않은 변경 여부를 주기적으로 점검하여 의심스로운 변화가 감지되면 이를 검사하고 복구하는 과정 , 오픈소스와 상용버전이 있음

-> 시스템 내에 지정한 중요한 디렉터리와 파일에 대한 정보를 담은 데이터베이스를 생성한 후 tripwire을 실행할 대 새로 생성된 데이터베이스와 비교하여 그 차이점을 보고해줌으로써 시스템 관리자가 시스템 내에 어떠한 변화가 있는지 감지할 수 있는 도구임 -> 무결한 상태에서 외부 공격자가 루트킷/백도어를 설치하였을 때 이러한 사실을 할 수 있게 해주는 도구 (공격자가 루트킷/백도어를 설치한 후 tripwire 데이터 베이스를 갱신하면 공격 사실을 알 수 없음)

* 루트킷 점검 도구 (chkrootkit): 루트킷은 지속적으로 자신의 존재가 탐지되지 않도록 숨기면서 관리자 권한의 획득과 백도어 등의 기능을 수행하는 코드와 프로그램의 집합 -> 초기에는 주로 서버 장비에 설치되어 패킷을 스니핑하면서 관리자 권한을 획득하는 방식이었음 -> 이것을 탐지하는 도구가 chrootkit

* 루트킷의 hidden process 탐지 원리
- /proc -> 유닉스/리눅스 커널이 메모리상에 사용하고 있는 모든 자원들에 대한 정보들을 파일 형식으로 보관하는 파일 시스템, 프로세스등의 자원, 커널 파라미터 등에 대한 상태정보를 파일명으로 보관하고 있음 , 메모리 영역에 존재하는 파일 시스템으로 부팅시마다 새롭게 생성 됨
- /proc/<pid>/exe : 프로세스의 실행파일 및 경로를 확인할 수 있는 심볼릭 링크 파일
- /proc/<pid>/cmdline : 프로세스를 실행한 명령어 및 전달인자 정보를 담고 있는 파일로 프로세스가 실행된 방식을 정확하게 파악하는데 활용 함

=> 일반적으로 루트킷은 공격자가 숨기고자 하는 프로세스가 출력되는 부분만 제거하고 출력하도록 ps 프로그램을 만들어 타겟 시스템에 있는 정상적인 ps 프로그램과 교체하는 방식으로 동작함 -> 루트킷 탐지 프로그램은 ps 실행 결과와 /proc 디렉터리에 있는 프로세스 정보를 비교하여 /proc 디렉터리에는 프로세스가 있지만 ps 실행 시 보이지 않는 프로세스를 히든 프로세스로 탐지함 -> 일반적으로 공격자는 백도어를 실행한 후 실행파일 흔적을 숨기기 위한 목적으로 위 예와 같이 실행 후 삭제하는 방식을 많이 사용함 -> 루트킷이 설치된 것으로 의심 된다면 변조/감염이 된 파일만 교체하는 것이 아니라 해당 시스템 전체를 재설치 하는 것이 좋음

* 루트킷 감지 여부 대응 방법
- RPM 명령을 이용하여 변조된 파일을 확인함

-> rpm -Uvh : 패키지파일이름.rpm : 해당 패키지 신규 설치 또는 업그레이드 수행

-> rpm -qf 파일절대경로 : 해당 파일이 어느 패키지에 포함되어 있는지 확인

-> rpm -V 패키지 이름 : V 옵션은 Verify를 의미하며 해당 패키지를 통해 설치된 파일의 무결성을 검사함 (S: 파일 크기 변경, M : 파일 퍼미션 변경, 5: MD5 체크섬 변경, T : 파일 수정시간 변경, U : 소유자 정보 변경, G : 소유 그룹 정보 변경, D : 장치 정보 변경, L : 심볼릭 링크 정보 변경

- strace 명령을 이용하여 변조된 파일을 확인함 -> strace 명령은 유닉스/리눅스 시스템에서 특정 프로그램의 시스템 콜과 시그널을 추적하는데 사용하는 디버깅 도구로 정상적인 프로그램과 변조된 프로그램의 시스템 콜을 비교하여 변조 여부를 확인할 수 있음

* 리눅스 파일 속성 변경 : 속성은 특정 파일 자체에 대한 허가를 의미한다 . 퍼미션과 다른 개념임 ! (퍼미션은 사용자에 따라서 특정권한을 부여하는 것을 의미함)
-> lsattr 명령은 특정 파일에 대한 속성을 확인하고자 할 때 사용하고 chattr 명령은 속성을 변경하고자 할 때 사용 함
-> lsattr -i : 파일을 읽기 전용 모드로 만듬 / lsattr -a : 해당 파일에 내용 추가만 허용함 (파일 내용 변경 및 삭제는 불가) / lsattr -A : 해당 파일의 Access Time을 변경하지 않음
-> chattr : + 속성을 통해 속성을 설정하고 - 속성을 통해 속성을 제거 함

* 리버스 쉘 : 역으로 타겟 서버가 클라이언트/공격자로 접속해서 클라이언트가 타겟 서버의 쉘을 획득하는 방식
-> 방화벽을 우회하여 쉘을 획득하기 위함 : 일반적으로 아웃바운드가 인바운드보다 정책이 느슨하기 때문
-> 리버스 쉘을 테스트하기 위해 netcat 프로그램(다양한 네트워크 프로그램을 시뮬레이션 하기 위한 목적으로 만들어진 프로그램)을 많이 사용함

* 칼리 리눅스 : 보안 테스트를 위한 오픈 소스 리눅스 배포판인 백트랙의 후속작
* 메타스플로잇 : 칼리 리눅스에 내장되어 있는 모의 침투 테스트 도구
* 익스플로잇 : 소프트웨어나 하드웨어의 버그 또는 취약점을 이용하여 공격자가 의도한 동작이나 명령을 실행하도록 하는 코드 또는 그런 행위
* 쉘코드: 익스플로잇에 성공하면 프로그램 실행 제어권을 획득하게 되고 공격자가 의도한 명령을 담고 있는 코드를 실행하는데 이를 쉘 코드라고 함
* 쉘 : 원하는 명령을 해석해서 처리해주는 명령어 해석기
* CVE : 공개적으로 알려진 소프트웨어의 보안취약점을 표준화한 식별자 목록 -> 공통의 유일한 명칭으로 취약점을 식별하기 위해 만들어짐
* CWE : 미국 비영리 회사인 MITRE 사가 중심이 되어 소프트웨어에서 공통적으로 발생하는 약점을 체계적으로 분류한 목록을 제공하기 위해 만들어짐 -> CWE/SANS TOP 25 는 미국 MITRE 및 SANS 연구소에서 발표하는 소프트웨어 개발자가 가장 범하기 쉽고 위험한 25가지 소프트웨어 취약점 목록을 유형별로 분류해놓은 것

cf. 보안 약점 : 공격에 잠재적으로 활용될 수 있는 소프트웨어의 결함, 오류
cf. 보안 취약점 : 해킹 등 실제 보안 사고에 이용되는 소프트웨어의 보안 약점이나 시스템상의 보안 허점

* DBD (Drive By Download) : 다운로드를 유도하는 공격 -> 공격자는 홈페이지를 해킹한 후 사용자 PC의 취약점을 익스플로잇하는 악성 스크립트와 악성코드를 은닉시키고 취약한 PC 환경의 사용자가 홈페이지에 접속할 경우 자신의 의도와는 무관하게 악성코드가 다운로드되어 설치되는 공격 기법 -> DBD 공격은 일반적으로 난독화된 악성 스크립트와 다수의 경유지/중계지를 거쳐 최종 유포지로 접속하여 악성코드를 다운로드하도록 유도함 -> 난독화로 인해 보안장비에 탐지 되기 힘들고 다수의 중계지를 거쳐 유포지에 대한 추적을 어렵게 함

-> 홈페이지를 통한 악성 코드의 유포 목적은 파밍형 악성코드를 통해 금융정보, 개인정보를 탈취하는 형태와 특정 타겟을 대상으로 악성코드를 유포하는 워터링홀 방식의 APT 공격이 주된 목적으로 나타나고 있음
-> 방문페이지 : 웹사이트를 방문했을 때 현재 브라우저가 보여주는 페이지
-> 경유페이지 : 악성 스크립트가 삽입되어 있는 방문페이지
-> 중계페이지 : 경유 페이지에서 유포 페이지로 연결해주는 징검다리 역할을 하는 페이지
-> 유포페이지 : 실제 익스플로잇 및 악성코드가 저장되어 있고 이를 유포하는 페이지

* 홈페이지 유포 악성코드 탐지 기술 : 정적 분석기술 -> 점검대상 홈페이지 웹 프로그램 소스코드를 분석하여 알려진 악성코드 경유지,중계지,유포지 또는 악성 스크립트 문자열을 포함하는 악성스크립트가 있는지를 탐지하는 방식 -> 알려진 탐지 패턴으로 점검하기 때문에 점검 속도는 빠르지만 알려지지 않은 신종 악성코드에 대해서는 탐지하지 못하는 한계가 있음 / 동적 분석기술 -> 가상의 이용자 PC환경을 구성하고 다양한 취약점에 노출시킨 후 점검 대상 홈페이지에 접속하여 비정상적인 레지스트리 변경, 악성코드 다운로드, C&C 서버 접속 등의 악성행위를 분석하는 기법 -> 이용자 환경에대한 행위분석이라고도하며 탐지 패턴을 이용하지 않기 때문에 신종 악성코드 탐지가 가능하나 상대적으로 분석 속도가 느린 단점이 있음

* 난독화 : 프로그램 코드를 읽기 어렵게 만드는 기술로 난독화의 대상에 따라 소스코드 난독화(프로그램 소스코드를 알아보기 힘들게 만드는 기술)와 바이너리 난독화(컴파일 후 생성된 바이너리를 역공학을 통해 분석하기 어렵게 변조함)로 구분 됨 -> 패턴/시그니처 보안장비의 탐지를 우회할 목적으로 사용 함

* 디페이스 공격 : 웹 사이트의 화면을 해커가 원하는 화면으로 바꾸고 해킹 성공을 알리는 공격으로 시각적으로 자신의 존재감을 알리고 정치적인 메시지나 자신의 실력을 과시하는 목적으로 사용 함

* 악성코드 이해하기 : 악성 행위를 위해 개발된 컴퓨터에서 동작하는 모든 소프트웨어 = Malware
- 다운로더 : 악성코드에서 지정한 외부 주소에 접속하여 추가 악성코드를 다운로드 하여 실행시키는 악성코드
- 드롭퍼 : 다운로드와 유사하게 새로운 악성코드를 생성하지만 다운로더가 외부에서 악성코더를 다운 받는 것에 비해 드롭퍼의 경우 자신이 내부에 포함되어 있는 데이터를 이용하여 악성코드를 생성한다는 차이점이 있음 (인젝터 : 드롭퍼

의 특수한 형태로 파일을 생성하지 않고 자신의 데이터를 이용해 바로 새로운 프로세스를 생성하여 메모리에 상주시키는 형태의 악성 코드)
- 키로거 : 컴퓨터가 입력하는 정보를 기록하는 것으로 그 중에서도 주로 키보드를 통한 메시지를 중간에 가로채서 기록하는 형태
- 백도어 : 감염된 사용자 PC에 특정 포트를 열어두어 정상적인 인증과정 없이 원격접속을 통해 직접 조작하는 형태로 사용자 몰래 특정 파일을 삭제하거나 파일이나 정보를 빼가는 등의 행위를 함
- 트로이목마 : 정상적인 소프트웨어의 형태를 띠지만 악의적인 행위를 포함하고 있는 악성코드를 말한다. 주로 일반 프로그램으로 가장하여 사용자가 다운로드해 실행하기를 기다리는 형태로 전파됨
- 랜섬웨어 : 사용자 파일을 암호화 시켜 일정 시간 안에 일정 금액을 지불하면 암호를 풀어주는 방식으로 사용자에게 금전적인 요구를 하는 악성코드를 말함
- 애드웨어 : 상업용 광고 목적으로 만들어진 악성코드로 웹 브라우저 시작 페이지 변경, 팝업 윈도우 생성 등의 동작을 함
- 스파이웨어 : 사용자 PC에 사전 동의 없이 설치되어 컴퓨터 정보와 개인정보를 수집하는 악성코드
- 바이러스 : 정상적인 파일이나 시스템 영역에 침입하여 그곳에 자신의 코드를 삽입하거나 설치하는 프로그램 -> 감염 방법이나 동작 원리에 따라 메모리 상주형, 파일, 덮어쓰기, 은폐형 등 여러가지로 세분화 됨
- 웜 : 바이러스처럼 다른 파일을 감염시키는 것이 아닌 자기 자신을 레지스트리에 등록하거나 복사본을 생성하여 전파하는 등의 독자적으로 실행되는 악성 코드를 말함 -> 이메일에 첨부되어 확산 되거나 P2P 파일 공유, 네트워크 공유등을 이용하여 스스로 증식하여 빠르게 확산되는 특징을 가지고 있음
- 루트킷 : 악의적인 행동을 하는 프로그램을 숨기기 위한 목적으로 시작된 악성코드로 현재는 프로세스나 파일 등의 흔적을 사용자가 볼 수 없도록 하는 프로그램에 대한 이름으로 사용 된다.
- 부트킷 : PC의 부팅영역인 MBR을 조작하는 프로그램을 칭하는 이름으로 파괴형(MBR, VBR을 의미 없는 문자열 등으로 덮어씌워 정상적인 부팅을 하지 못하게 만드는 형태)과 은신형(VBR의 빈 영역에 악성코드를 설치하여 백신이 탐지하지 못하도록 하는 형태)으로 나뉨.

cf. 패킹 : 실행파일의 크기를 줄이고 내부 코드와 리소스를 감추기 위해 압축 또는 암호화 하는 기법 -> 배포를 쉽게 하고 암호화를 통해 소스코드분석을 방지함, 악성코드의 경우 자신의 행위가 리버스 엔지니어링을 통해 분석되는 것을 방지함
cf. 언패킹 : 패킹된 실행 파일을 푸는 것
cf. 리버스엔지니어링 : 역공학, 소프트웨어의 한 분야로 이미 만들어진 시스템/소프트웨어를 역으로 추적하여 기술적인 원리나 구조를 알아내는 과정

* 악성코드 분석 방법 : 정석분석 -> 디버거와 디스어셈블러를 이용하여 실제 악성코드를 직접 실행하지 않고 디버깅 및 코드를 분석하는 방법 (아이다, 올리디버거)/ 동적분석 -> 악성코드를 제한된 실행환경 내에서 직접 실행해봄으로써 동작 과정 및 시스템 내에서의 행위를 모니터링하여 분석하는 기법 -> 파일 접근, 레지스트리 접근, 프로세스 접근, 네트워크 이용등에 대해 분석함

* 윈도우 PE 파일 : 윈도우의 실행파일 포맷 -> 실행파일이 적재되는 가상주소, import 함수 목록, export 함수 목록, 데이터, 코드 등의 정보를 관리하기 위해 파일의 첫 부분에 여러가지 구조체로 구성되어 있음 -> PE 파일 유형에 exe, scr, dll, ocx, sys, obj 등이 있음

* 윈도우 PE 파일 섹션 구조 : 섹션 헤더는 각 섹션 데이터를 메모리에 로딩하고 속성을 설정하는데 필요한 정보를 가지고 있음 -> 섹션은 PE 파일이 가상 주소 공간에 로드된 이후 프로그램 실행 코드, 데이터, 리소스 등 프로그램 실행에 필요한 정보를 배치한 영역을 말한다.
p. 579 에 section 종류가 정리 됨

* 윈도우 레지스트리 : 윈도우 시스템이 운영되는데 필요한 정보를 담고 있음, 키와 값 형태로 구성 됨 -> 키는 최상위 루트키와 그 하위의 서브키로 구분할 수 있으며 값은 이름,데이터유형,데이터로 구분 됨
- 하이브 파일 : 레지스트리 정보를 저장하고 있는 물리적인 파일로 오프라인 상태인 비활성시스템에서 레지스트리를 분석할 때 사용함 -> SAM : 계정정보 및 접속 기록, SECURITY : 시스템보안 정책 및 권한정보, SOFTWARE : 시스템에 설치 된 모든 application 정보, SYSEM : 시스템 관련 설정 정보, NTUSER.dat : 사용자별 환경설정/프로파일 정보

-> 레지스트리는 윈도우 부팅 시 하이브 파일에서 값을 읽어 들여 구성함. 하이브 파일에서 직접 읽어 들여 구성되는 키를 Master Key라고하고 Master Key로 부터 값을 가져와서 재구성 하는 키를 Derived Key 라고 한다

- Master Key : HKLM(HKEY_LOCAL_MACHINE), HKU(HKEY_USERS)
- Derived Key : HKCU(HKEY_CURRENT_USER), HKCC(HKEY_CURRENT_CONFIG), HKCR(HKEY_CLASSESs_ROOT)
- regedit 명령을 통해 메모리 상에 있는 레지스트리 자료 구조 정보를 보여주고 이를 관리할 수 있다

* 최상위 루트키
- HKCR(HKEY_CLASSES_ROOT) : 파일 확장자와 확장자에 대한 연결 프로그램 정보를 가지고 있다
- HKCU(HKEY_CURRENT_USER) : 현재 로그인 중인 사용자의 환경설정/프로파일 정보를 가지고 있음, 주요 환경설정 정보에는 제어판 설정/네트워크 연결/응용 프로그램 등이 있으며 HKU 루트키에 있는 해당 사용자 정보에 대한 링크를 가지고 있음
- HKLM(HKEY_LOCAL_MACHINE) : 개별 사용자 단위가 아닌 시스템 전체에 적용되는 하드웨어와 응용 프로그램의 설정 데이터를 저장함
- HKU(HKEY_USERS) : 다중 사용자 환경에서 각 사용자별로 키 항목을 생성하여 환경설정/프로파일 정보를 저장함

-> 각 사용자별로 존재하는 하이브 파일잉ㄴ ntuser.dat 파일을 로드하여 생성됨
- HKCC(HKEY_CURRENT_CONFIG) : 현재 사용중인 윈도우의 하드웨어 프로필 정보를 가지고 있음 -> 디스플레이 정보, 폰트 정보

* APT : 지능형 지속위협은 특정표적을 대상으로 취약점을 파악하고 다양한 공격 기법을 이용한 지속적인 공격활동으로 정보 탈취, 시스템 파괴 등의 손상을 입히는 공격 프로세스/절차를 의미함
-> APT 공격 단계 : 초기 정찰, 초기 침입(악성코드 유입 -> 스피어 피싱/워터링 홀/USB 메모리 스틱), 거점 마련(리버스 쉘 형태의 백도어 연결), 권한 상승 (익스플로잇, 제로데이 공격 등을 수행하여 시스템 관리자로의 권한 상승을 얻어냄), 내부정찰(공격 도구를 활용하여 공격 대상 내부 시스템/네트워크 정보를 수집함), 내부 침투(내부 정찰을 통해 수집한 정보를 이용하여 내부 네트워크 상에 있는 다른 시스템을 추가로 공격하고 제어 권한을 탈취함), 지속성 유지 (윈도우 레지스트리 조작을 통한 시작 프로그램등록,서비스등록,작업스케줄러 등록등 다양한 방식 이용), 목표 달성 (정보 유출, 시스템 파괴)

cf. 스피어 피싱 : 불특정 다수가 아닌 특정인을 표적으로 신뢰할만한 발신인이 보낸 것 처럼 위장한 이메일을 발송, 악성 웹사이트로 유도 또는 악성 첨부 파일로 악성 코드에 감염시키는 방식

cf. 워터링 홀 : 공격자는 사회공하긱법을 통해 공격 대상이 주로 방문하는 웹사이트에 대한 정보를 사전에 파악한 후 제로데이 취약점 등을 이용하여 해당 사이트에 악성 코드를 심어두고 공격 대상이 해당 사이트에 접근하게 되면 악성코드에 감염되는 방식

cf. USB 메모리 스틱 : 공격자는 사전에 USB 메모리에 악성코드를 삽입. 특정 타겟조직의 이동 동선상에 이를 방치한 후 누군가 이를 가져가서 내부 PC에 연결하는 순간 감염되는 방식

* 사이버 킬 체인 : 사이버 상에서 표적에 대한 공격을 위해 일련의 공격 단계를 거치는데, 이러한 공격 단계중 어느 한 단계의 공격을 탐지/차단/대응해 목표 달성 이전에 선제적으로 무력화 시키는 방어 시스템
-> 록히드마틴의 등록상표로 여러 단계를 거쳐 장기간에 진행되는 APT 공격에 대응하는 효과적인 전략
-> 탐지(공격자의 공격 행위를 발견), 거부(공격자의 접근을 차단), 교란(공격을 위한 정보의 흐름을 방해하는 행위), 약화(공격 행위의 효율 또는 효과를 감소시킴), 기만(정보를 조작하여 공격자가 잘못된 판단을 하게 하는 행위), 파괴(공격자 또는 공격 관련 도구가 원래의 기능을 수행할 수 없게 손상시키고 복원이 불가능하도록 하는 행위)

cf. SSH 포트 포워딩 : SSH클라이언트가 SSH서버에 접속하여 만든 연결을 다른 애플리케이션에서 이용할 수 있는 통신기술 = 포트 포워딩 , 터널링 -> 방화벽을 우회하여 내부 시스템에 침투하는 등의 공격에 활용될 수 있음 -> 애플리케이션이 접속할 리스닝 포트는 여는 방식에 따라 로컬 포트 포워딩(애플리케이션 클라이언트가 접속할 리스닝포트를 SSH 클라이언트 호스트에 생성하여 포워딩하는 방식)과 리모트 포트 포워딩(애플리케이션 클라이언트가 접속할 리스닝을 SSH 서버 호스트에 생성하여 포워딩하는 방식)으로 구분할 수 있음

- 로컬 포트 포워딩 : SSH -L "로컬 리스닝 포트" : "포워딩할 호스트주소" "SSH서버 주소"
- 리모트 포트 포워딩 : SSH -R "원격 리스닝 포트" : " 포워딩할 호스트주소" "SSH서버 주소"

* NTFS 파일 시스템
- 파티션 : 물리적 디스크를 구획화하여 논리적인 영역을 나누는 것을 파티셔닝이라고하고 나눈 영역을 파티션이라고 한다
- 파일시스템 : 파일을 읽고 쓰고 삭제하고 인덱싱하는 등 파일을 관리하기 위한 자료구조를 파일 시스템이라고 함
- 포맷 : 파티션에 파일 시스템을 구성하는 작업

* NTFS -> MBR (마스터 부트 레코드) : 파티션 생성시 물리적 디스크의 첫 번째 섹터에 위치하는 512 byte 크기의 영역을 말함

* NTFS 파일 시스템 구조
- VBR : NTFS 구조에서 가장 앞부분에 위치하는 영역으로 윈도우 부팅을 위한 기계어 코드와 볼륨 및 클러스터의 크기, MFT의 시작주소 등 설정 정보를 담고 있으며 파티션의 가장 마지막 섹터에 VBR 백업본을 가지고 있다

cf. 섹터 : 물리적 디스크에서 사용하는 최소의 저장단위로 512 byte 로 이루어져 있음
cf. 클러스터 : 섹터 여러개를 하나로 묶어서 데이터 저장의 최소 단위로 사용하는데 이를 클러스터 라고 함

- MFT : 마스터 파일 테이블 -> 볼륨/파일 시스템에 존재하는 모든 파일과 디렉터리에 대한 정보를 담고 있는 테이블로 NTFS 에서 가장 중요한 영역임. 파일이나 디렉터리의 수에 비례하여 점점 커짐, MFT 엔트리 집합으로 구성되어 있음 -> 엔트리는 하나의 파일 또는 디렉터리에 대한 정보를 담고 있는 자료구조로 파일의 위치, 시간 정보, 크기 , 파일 이름 등 다양한 속성 정보들로 구성되어 있다 -> 악성코드 분석시 MFT 엔트리 속성으로 MAC Time 이 있음

cf. MAC TIME -> M : Modification Time, 파일의 내용을 마지막으로 수정한 시간 / A : Access Time, 파일에 마지막으로 접근한 시간 / C(Creation Time), 파일을 최초로 생성한 시간 -> inode 구조체 에서는 Change Time 이 파일 속성이 마지막에 변경된 시간임

* 디스크 파괴형 악성코드 : 마스터 부트 레코드 또는 볼륨 부트 레코드 영역을 훼손하여 컴퓨터가 정상적으로 부팅되지 않도록 하는 악성 코드 -> MBR 은 부트코드를 정상ㅇ적인 디스크에서 복사하고 각각의 파티션 정보를 수집하여 파티션 테이블을 완성함으로써 복구 가능하고 VBR은 파티션의 가장 마지막 섹터에 있는 VBR 백업본을 덮어써서 복구가 가능함

* shellShock (= GNU Bash 취약점) -> 취약한 버전의 bash 는 환경변수의 함수 선언문 뒤에 임의의 명령어를 삽입할 경우 환경변수에 설정된 함수선언 시 함수선언의 끝을 인지하지 못하고 삽입한 명령어까지 실행하는 취약점이 존재함 -> bash가 제공하는 함수선언 기능에 대한 취약점 -> 쉘 쇼크 ->

* 쉘 쇼크를 사용한 취약점 공격 유형
- CGI (Common Gateway Interfac) : 웹 서버에 요청된 페이지를 응용 프로그램에 전달하고 처리하기 위한 인터페이스
- 쉘 쇼크 : 취약점에 의해 영향을 받는 프로그램들 중 가장 대표적인 CGI -> 공격자가 헤더 정보에 함수와 명령어를 추가하여 전송하면 해당 명령어가 실행되는 취약점이 발생함

* 리버스 쉘 연결 유형 : /dev/tcp 특수파일을 통한 리버스쉘 연결, nc 프로그램을 이용한 리버스 쉘 연결, 악성코드 다운로드 유형, 웹 쉘 생성 유형

* 리버스 쉘 대응 방안 : 취약한 버전의 Bash를 사용하고 있는 경우 최신 버전으로 업데이트 함, CGI 서비스의 사용 유무를 확인하여 해당 서비스를 사용하지 않는 경우 서비스를 중지시키거나 CGI를 삭제함 , 네트워크 보안 장비 단에서 공격 시그니처를 등록하여 차단함

* 하트블리드 : 통신 구간 암호화를 위해 많이 사용하는 OpenSSL 라이브러리의 하트비트 확장 모듈의 버그로 인해 발생한 취약점으로 서버에 저장된 중요 메모리 데이터가 노출되는 취약점이 발견 됨
=> 대응방안 : 취약점이 존재하지 않는 버전으로 OpenSSL 업데이트 , 취약점 공격 탐지 및 차단 룰/패턴 적용, 인증서 재발급, 사용자들의 비밀번호 재설정 유도

* 프리크 취약점 : 프랑스 국립 연구소 및 MS사에서 SSL을 통해 강제로 취약한 RSA로 다운그레이드 시킬 수 있는 취약점을 발견 -> 공격자가 MITM 공격을 통해 512비트 RSA로 다운그레이드시켜 정보를 유출시킬 수 있음
=> 대응 방안 : OpenSSL 버전 업그레이드, OpenSSL의 RSA_EXPORT cipher suite 비활성화, 취약점에 영향을 받는 OS 및 브라우저는 업그레이드 필요

* 로그잼 : 중간자 공격을 통해 사용자와 웹, 이메일 서버간의 TLS 통신을 다운그레이드 시킬 수 있음
-> HTTPS 연결에서 OpenSSL을 포함하고 있는 SSL/TLS 클라이언트를 다운그레이드 시킬 수 있는 공격
=> 대응 방안 : 클라이언트는 최신의 브라우저를 사용함, 서버는 명시적으로 Export용 cipher suite를 사용하지 않음 , 2,028비트의 디피-헬만 그룹을 생성하거나 타원 곡선 디피엘만 cipher suite를 사용

* 푸들취약점 : SSL/TLS 협상시 버전 다운그레이드 공격을 통해 SSLv3.0을 사용하도록 강제한 후 MITM 공격을 통해 암호화되어 송수신되는 쿠키 정보나 데이터를 추출하는 공격을 말함 -> CBC 모드를 사용하는 경우 발생하는 패딩된 암호 블록이 MAC에 의해 보호되지 않는 취약점을 이용함
=> 대응책 : SSLv3.0을 사용하지 않도록 웹서버 SSL 설정을 함, OpenSSL을 최신버전으로 업그레이드 함

* DROWN 취약점 : 취약한 구식 암호화 기법을 통한 RSA 복호화에따온이름으로 SSLv2.0 취약점을 악용한 교차 프로토콜 공격 -> 공격자는 SSLv2.0을 사용하는 서버에 악성 패킷을 보내 인증서 키값을 알아내고 키 값을 이용해 암호화된 통신내용을 복호화해 주요 정보를 탈취할 수 있음
=> 대응책 : SSLv2.0을 사용하지 않도록 웹서버 SSL 설정을 하고 OpenSSL을 최신버전으로 업그레이드 함

* NTP 분산 서비스 거부 취약점 : 네트워크를 통해 컴퓨터 시스템 간 시간 동기화를 위해 사용하는 인터넷 프로토콜을 NTP 프로토콜이라고한다 (UDP/123) -> NTP 서버의 특정 명령어를 이용하여 대규모 증폭, 반사 형태의 디도스 공격을 유발시킬 수 있는 취약점 -> NTP 서버의 monlist 명령어(최근 접속한 최대 600개의 접속 호스트를 응답받을 수 있음) 사용
=> 대응책 : 취약한 NTP 데몬 서버 버전을 업그레이드 함, 버전 업그레이드가 어려운 경우 monlist 기능을 해제함 (ntp.conf 파일에 disable monitor 추가, ntpdc -n -c monlist [ip정보] 명령어를 통해 적절하게 조치되었는지 확인할 수있음, 보안 장비등을 통해서도 차단할 수있다.

* ntpdate - q "NTP 서버" -> NTP 서버의 날짜/시간 정보 확인
* ntpdate "NTP 서버" -> NTP 서버의 날짜/시간 정보를 현재 서버에 설정함

* SSDP 분산 서비스 거부 취약점 : SSDP -> 네트워크 상의 서비스나 정보를 검색하는 프로토콜로 프린터, 스캐너, IP 카메라 등 다양한 IoT 기기의 네트워크 탐색 용x도로 사용되며 UDP 1900 번을 사용한다.
-> SSDP 프로토콜을 악용하여 대규모 증폭,반사 형태의 디도스 공격을 실행한 사례가 보고 되고 있음
=> 대응 방안 : 업무에 불필요한 UDP포트 차단 및 UDP 서비스를 중지함, 보안장비를 이용하여 임계치 기반의 UDP 패킷 차단 정책을 적용 함